

CSV Employee Upload + Enterprise SSO Login Logic

A practical architecture guide for tenant-based employee provisioning, domain-based SSO routing, and secure role-aware login.

Purpose

This document explains how SimplyDSE can let a client upload employees by CSV and allow those employees to sign in using their existing company identity provider, such as Microsoft Entra ID, Google Workspace, Okta, or another enterprise SSO provider.

1. The Core Idea

CSV upload and SSO are two different systems that work together.

Part	Responsibility
CSV upload	Creates a SimplyDSE employee profile and confirms that this person is allowed into the tenant workspace.
SSO	Verifies the employee identity using the client company's identity provider.
Account linking	Matches the SSO-authenticated email to the pre-created employee record.
RBAC	Decides which dashboard the user should see after login.

Important security principle

A company email domain alone should not grant access. Access should require: verified domain + successful SSO + pre-provisioned employee record.

2. Recommended High-Level Flow

1. Super Admin creates the tenant organisation.
2. Tenant domain is added and verified, for example zhed.com.
3. SSO provider is configured for that tenant.
4. HR uploads employees by CSV inside that tenant.
5. System validates that uploaded employee emails match approved tenant domains.
6. Employees are pre-provisioned with status such as invited or pre_provisioned.
7. Employee goes to zhed.simplydse.online or app.simplydse.online/login.

8. System detects tenant and/or email domain.
9. System redirects employee to the correct SSO provider.
10. SSO returns verified identity to Supabase Auth.
11. SimplyDSE matches verified email to uploaded employee record.
12. System links auth_user_id to employee profile.
13. System resolves role and redirects user to the correct dashboard.

3. Key Database Concepts

Use the existing Supabase schema where possible. If tables or fields are missing, add them carefully using additive migrations only.

Table / Concept	Purpose
organisations	Stores tenant workspace identity and SSO requirements.
organisation_domains	Stores verified company email domains such as zhed.com.
organisation_sso_providers	Stores SSO configuration for each tenant.
employees	Stores HR-uploaded employee profiles and links to auth users after first login.
profiles / user_roles	Stores role and dashboard access logic if already used in the app.
audit_logs	Records provisioning, SSO linking, failed access, and role changes.

4. Suggested Table Fields

organisations

- id
- name
- slug
- primary_domain
- sso_enabled
- sso_required
- created_at
- updated_at

organisation_domains

- id
- organisation_id
- domain
- verified
- sso_enabled
- created_at
- updated_at

organisation_sso_providers

- id
- organisation_id
- provider_type
- provider_name
- domain
- metadata_url
- entity_id
- sso_url
- certificate
- status
- created_at
- updated_at

employees

- id
- organisation_id
- email
- first_name
- last_name
- department
- job_title
- role
- status
- auth_user_id
- sso_required
- last_login_at
- created_at
- updated_at

5. CSV Upload Logic

When HR uploads a CSV, SimplyDSE should validate every row before creating or updating employees.

Step	Action
1	Read CSV file and normalise email addresses to lowercase.
2	Validate required fields: first_name, last_name, email, department/job title where required.
3	Extract email domain from each employee email.
4	Confirm the domain belongs to the current tenant and is verified.
5	Check for duplicate employee emails inside the same organisation.
6	Create or update employee profile records.
7	Set default role to employee unless HR explicitly assigns another permitted role.
8	Set status to pre_provisioned or invited.
9	Leave auth_user_id empty until the employee signs in

	successfully through SSO.
10	Create audit log entries for import success/failure.

CSV upload rule

Do not create passwords for SSO employees. Their real login identity lives in the client's identity provider.

6. Login Logic

Path A: Tenant Subdomain Login

Example: edime@zhed.com goes to zhed.simplydse.online.

- Resolve tenant from subdomain: zhed.
- User enters company email.
- Extract domain: zhed.com.
- Confirm zhed.com belongs to the zhed organisation and SSO is enabled.
- Confirm employee record exists for email + organisation_id.
- Redirect to tenant's SSO provider.
- After successful SSO, match the verified email to employee record.
- Link auth_user_id if this is the first login.
- Resolve role from SimplyDSE database.
- Redirect to employee, HR, manager, or admin dashboard.

Path B: General Login

Example: employee goes to app.simplydse.online/login.

- User enters company email.
- System extracts email domain.
- System finds matching verified organisation domain.
- If exactly one tenant matches, route user to tenant SSO flow or tenant subdomain.
- If no tenant matches, show a safe login error or normal email/password login option if allowed.
- If multiple tenants match, require a tenant-specific workspace URL or additional selection.

7. First-Time SSO Account Linking

This is the most important part of the logic. SSO proves identity, but SimplyDSE decides access.

Step	Action
1	Get verified email from Supabase Auth after SSO callback.
2	Normalise email to lowercase.
3	Extract email domain.
4	Find organisation using verified organisation_domains.
5	Find employee record by email + organisation_id.
6	If found, link auth_user_id to employee profile.
7	Set employee status to active.
8	Update last_login_at.
9	Resolve role from database.

10	Redirect to correct dashboard.
----	--------------------------------

If employee record is missing

Block access by default. Show: “Your company login was successful, but your SimplyDSE employee profile has not been created yet. Please contact HR.” This prevents anyone with the company domain from entering without being authorised.

8. Role Routing After SSO

Role	Suggested Route	Destination
employee	/employee	Employee Dashboard
hr_manager	/dashboard or /hr	HR Dashboard
manager	/manager	Manager Dashboard
organisation_admin	/admin or /organisation-admin	Organisation Admin Dashboard
super_admin	/super-admin	Platform Admin Dashboard

The role should come from the SimplyDSE database, not from the SSO provider alone. The identity provider verifies who the user is; SimplyDSE controls what they are allowed to access.

9. SAML, OIDC, OAuth: Which Should SimplyDSE Use?

Protocol	Recommendation
SAML 2.0	Best first enterprise SSO path for clients using Microsoft Entra ID, Google Workspace, Okta, OneLogin, and other enterprise IdPs.
OpenID Connect	Useful for modern identity integrations, but may require custom provider support depending on your auth setup.
OAuth social login	Good for “Continue with Google/Microsoft”, but not always the same as tenant-specific enterprise SSO.

Recommended rollout

Phase 1: Email/password + Google/Microsoft OAuth for smaller clients. Phase 2: CSV pre-provisioning + domain matching. Phase 3: Tenant-specific SAML SSO for enterprise clients. Phase 4: OIDC/custom providers later if a client specifically requires it.

10. Cost and Charging Considerations

Enterprise SSO may create additional cost depending on the Supabase plan and usage. Supabase documents enterprise SSO support through SAML 2.0, and its pricing currently states that Single Sign-On (SAML 2.0) is not included in the Free plan. Supabase also describes SSO MAUs as distinct users who log in or refresh tokens during the billing cycle using a SAML-compatible identity provider.

Feature	Cost implication
CSV upload only	Usually low cost: mostly database inserts, reads, validation, and storage if files are kept.
Email/password or social OAuth	Counts as normal auth usage/MAUs according to the auth provider pricing rules.
Enterprise SAML SSO	May require a paid plan and may count SSO MAUs.

High-volume clients	Costs may also include database usage, storage, edge functions, email delivery, and egress.
---------------------	---

11. Security Rules

- Do not allow access based only on company domain.
- Require verified domain + successful SSO + pre-provisioned employee record.
- Default CSV-imported users to employee role unless explicitly changed by an authorised HR/admin user.
- Validate tenant on every login and every employee lookup.
- Never expose service role keys on the client.
- Do not bypass RLS policies.
- Employees can only see their own records and assessments.
- HR users can only manage employees inside their organisation.
- Super Admin support access to tenant data should be controlled and audited.

12. Recommended Implementation Checklist

1. Create organisation domain verification model.
2. Add SSO provider configuration per tenant.
3. Update CSV import to validate email domain against tenant domains.
4. Pre-provision employee records without passwords.
5. Build domain-based login routing.
6. Implement SSO callback account linking.
7. Enforce role-based dashboard routing.
8. Add safe error states for missing employee records.
9. Add audit logging for CSV import, SSO linking, failed access, and role changes.
10. Test with one tenant and one identity provider before adding more providers.

13. Example End-to-End Scenario

Tenant: Zhed

Domain: zhed.com

Employee uploaded by HR: edime@zhed.com

1. HR uploads edime@zhed.com via CSV.
2. System confirms zhed.com is a verified domain for the Zhed organisation.
3. System creates employee record with role = employee and status = pre_provisioned.
4. Edime visits zhed.simplydse.online.
5. Edime enters edime@zhed.com.

6. System detects SSO is required for zhed.com.
7. Edime is redirected to Zhed's SSO provider.
8. SSO returns a verified user with email edime@zhed.com.
9. SimplyDSE matches the email to the uploaded employee record.
10. SimplyDSE links auth_user_id, activates the employee, resolves role, and sends Edime to the Employee Dashboard.

14. Recommended Decision

Build the CSV pre-provisioning, verified domain matching, and account-linking logic now. Treat full enterprise SAML SSO as an enterprise-tier feature once the product is ready for real client onboarding. This gives SimplyDSE a strong enterprise-ready architecture without overcomplicating the first production build.

Sources Checked

- Supabase Enterprise SSO docs: <https://supabase.com/docs/guides/auth/enterprise-sso>
- Supabase SAML SSO docs: <https://supabase.com/docs/guides/auth/enterprise-sso/auth-sso-saml>
- Supabase SSO login flows: <https://supabase.com/docs/guides/platform/sso>
- Supabase SSO MAU usage docs: <https://supabase.com/docs/guides/platform/manage-your-usage/monthly-active-users-sso>
- Supabase pricing: <https://supabase.com/pricing>